

Demo: watch the merge gate stop a secret

This demo shows the merge gate at work on a real pull request, safely. It uses a **demo token**: a fake key for ACME Pay, the payment provider SecureGate invented for its demos. The token unlocks nothing. GitHub's push protection (GitHub's own check for known key formats) does not know this format, so the token reaches the pull request, and SecureGate can show what it does.

This repository is public. **Only ever use demo tokens here, never a real key.**

Before you start: the repository is on GitHub, and PowerShell is open in the SecureGate folder. It takes about five minutes.

1. Make a branch

```
git switch main
git pull
git switch -c demo/secret-gate
```

A **branch** is a separate line of work, so main stays untouched.

2. Add a line with a demo token

```
$token = .venv\Scripts\securegate demo-token
Set-Content -Path demo_leak.py -Value "ACME_PAY_API_KEY = '$token'" -Encoding utf8
git add demo_leak.py
git commit --no-verify -m "Demo: add a fake ACME Pay token"
```

`securegate demo-token` makes a new random token every time. The file sits in the top folder on purpose: in `tests/`, `fixtures/` or `docs/`, the policy would only warn.

If the laptop gate is installed (`make hooks`), a plain `git commit` stops right here and shows the blocked token. `--no-verify` skips it on purpose, to show that the merge gate catches what gets past a laptop.

3. Push and open a pull request

```
git push -u origin demo/secret-gate
```

On GitHub, select **Compare & pull request**, then **Create pull request**. Do not merge it.

4. See the red check

After about a minute, the check **secret-gate** shows a red cross, and SecureGate posts a comment on the pull request: "SecureGate: BLOCKED (exit code 1)", `demo_leak.py:1` with the masked token (such as `acme*****9Qz`), **rule 8: provider-keys**, found by Gitleaks and TruffleHog, and a checklist to rotate the key. The full token is never shown. The same report is on the check's page: select **Details**, then **Summary** at the top left if you see a list of steps.

5. Delete the line in a new commit

```
git rm demo_leak.py
git commit -m "Demo: remove the token"
git push
```

6. See that the check is still red

The check runs again and stays red, and SecureGate updates its comment instead of adding a new one. The newest version of the code no longer has the token, but the pull request's first commit still does, and the gate scans every commit. Anyone who can see the pull request can open that commit and read the token. With a real key, this is the moment to revoke it at the provider: deleting the line did not undo the leak.

7. Clean up

On GitHub, select **Close pull request**. Never merge it. Then delete the branch:

```
git switch main
git branch -D demo/secret-gate
git push origin --delete demo/secret-gate
```

GitHub keeps the closed pull request and its commits. That is fine here, because the token is fake.

If this was the first time the check ran, you can now make it required: see [The two gates \(merge-gate.pdf\)](#), the one-time setting.